SOC FINAL INCIDENT REPORT

Lab 4: Credential Attack Investigation

1. Incident Overview & Triage Metadata

Incident Title:	LSASS Memory Dumping, Registry Theft, and Data Exfiltration via LOLBins
Assigned Severity:	**CRITICAL**
Affected Host:	SRV-APP-02
Compromised Account:	SRV-APP-02\admin_backup
Incident Timeframe:	2026-10-11 11:19:35 to 2026-10-11 11:20:55 (+05:30)
Detection Source:	Splunk Enterprise (index="soc-investigation", source="*credential_attack*")

2. Executive Summary

On August 17, 2026, starting at **11:19:35**, a compromised local administrative account (**SRV-APP-02\admin_backup**) on application server **SRV-APP-02** executed a coordinated credential-theft and data-exfiltration attack. The threat actor used Living-off-the-Land Binaries (LOLBins) in an attempt to bypass endpoint defenses, invoking **rundll32.exe** alongside **comsvcs.dll** to dump the memory of **lsass.exe** with `0x1fffff` access into `C:\Windows\Temp\debug_crash.dmp`.

Immediately following the memory dump, the attacker used **reg.exe** at **11:19:50** to export the offline SAM, SYSTEM, and SECURITY registry hives. To stage the theft, **makecab.exe** compressed the stolen data into `diag_report.cab`; **curl.exe** then exfiltrated the archive over the network to external C2 server `198.51.100.77:8443`. At **11:20:55**, the attacker issued a command-line deletion using `cmd.exe /c del` to forcefully wipe the extracted dump and registry hives from the temporary directory in an attempt to destroy forensic evidence.

3. Reconstructed Process Ancestry & Attack Timeline

Process	Observed Activity
rundll32.exe	Executed `comsvcs.dll MiniDump` to `debug_crash.dmp` (11:19:35 | EventCode 4688 / 10)
reg.exe	Saved `HKLM\SAM` to `sam.hiv` (11:19:50 | EventCode 4688 / 11)
reg.exe	Saved `HKLM\SYSTEM` to `sys.hiv` (11:19:58 | EventCode 4688 / 11)
reg.exe	Saved `HKLM\SECURITY` to `sec.hiv` (11:20:10 | EventCode 4688 / 11)
makecab.exe	Compressed `debug_crash.dmp` into `diag_report.cab` (11:20:25 | EventCode 4688 / 11)
curl.exe	Connected to `198.51.100.77:8443` and POSTed `diag_report.cab` (11:20:40 | EventCode 4688 / 3)
cmd.exe	Executed `del /f /q debug_crash.dmp and *.hiv` (11:20:55 | EventCode 4688)

4. Confirmed MITRE ATT&CK Mapping

Timestamp	EventCode	Tactic	Technique ID & Name	Supporting Log Evidence
11:19:35	4688, 10	Credential Access	T1003.001 – OS Credential Dumping: LSASS Memory	rundll32.exe loaded comsvcs.dll and requested `0x1fffff` access to lsass.exe.
11:19:50–11:20:10	4688, 11	Credential Access	T1003.002 – OS Credential Dumping: Security Account Manager	reg.exe save command exported SAM, SYSTEM, and SECURITY hives to disk.
11:20:25	4688, 11	Collection	T1560.001 – Archive Collected Data: Archive via Utility	Native makecab.exe deployed to compress the stolen memory dump into a .cab archive.
11:20:40	4688, 3	Exfiltration	T1048.003 – Exfiltration Over Alternative Protocol: Unencrypted	curl.exe utilized to POST the archive to external IP 198.51.100.77 via port 8443.
11:20:55	4688	Defense Evasion	T1070.004 – Indicator Removal: File Deletion	cmd.exe /c del /f /q command wiped all staging artifacts from C:\Windows\Temp\.

5. Indicators of Compromise (IOCs)

Indicator Type	Value	Context
External IPv4 / Ports	198.51.100.77 (TCP 8443)	Outbound C2 channel utilized for curl.exe exfiltration.
File Artifact (Created/Deleted)	C:\Windows\Temp\debug_crash.dmp	Stolen LSASS memory dump.
File Artifact (Created/Deleted)	C:\Windows\Temp*.hiv	Offline Registry hives (sam.hiv, sys.hiv, sec.hiv).
File Artifact (Exfiltrated)	C:\Windows\Temp\diag_report.cab	Compressed staging archive containing the stolen credentials.

Analyst Conclusion

The reconstructed telemetry presents a continuous sequence from unauthorized LSASS memory access and registry-hive extraction through data compression, outbound network exfiltration, and immediate indicator removal. Because the SAM hive and LSASS memory were successfully exfiltrated before deletion, this incident is documented in the lab as a **CRITICAL**-severity compromise requiring immediate endpoint containment, mandatory enterprise-wide credential rotation for any accounts accessing SRV-APP-02, and perimeter network blocking.